

S5L4

“ChatGPT, potresti fornirmi una spiegazione dettagliata su cos'è il social engineering e una descrizione completa di tutte le tecniche utilizzate dagli attaccanti ? Per ogni tipologia di attacco, includi esempi reali di attacchi e consigli pratici su come difendersi efficacemente da ciascuno di essi. Inoltre, potresti fornirmi una lista aggiornata dei CVE relativi a Google Chrome? Vorrei anche informazioni dettagliate su alcune di queste vulnerabilità, compresi i rischi associati e le soluzioni o mitigazioni consigliate per ciascuna.”

Social Engineering: Definizione, Tecniche, Esempi e Difesa **Cos'è il Social Engineering**

Il social engineering è una strategia di attacco che sfrutta la manipolazione psicologica per indurre le persone a divulgare informazioni riservate, fornire accesso a sistemi protetti o compiere azioni che compromettono la sicurezza. Gli attaccanti fanno leva su emozioni come fiducia, paura, urgenza o curiosità, bypassando così le misure di sicurezza tecniche.

Tecniche Principali di Social Engineering

1. Phishing

- **Descrizione:** Invio di email o messaggi fraudolenti che sembrano provenire da fonti affidabili per ottenere dati sensibili o far scaricare malware.
- **Esempio reale:** Nel 2016, una campagna di phishing ha compromesso account email del Partito Democratico USA, rivelando informazioni riservate.
- **Difesa:** Non cliccare link sospetti, verificare sempre mittenti, utilizzare autenticazione a due fattori (2FA).

2. Spear Phishing

- **Descrizione:** Variante mirata del phishing con messaggi personalizzati per vittime specifiche.
- **Esempio reale:** Attacco a CEO con email apparentemente da colleghi, che ha portato a furti milionari.
- **Difesa:** Formazione mirata, doppia verifica richieste sensibili, attenzione ai dettagli nelle email.

3. Vishing (Phishing vocale)

- **Descrizione:** Frodi telefoniche dove l'attaccante si finge autorità (banca, IT) per estorcere informazioni.
- **Esempio reale:** Truffatori che chiamano fingendo di essere dalla banca chiedendo codici PIN.
- **Difesa:** Non fornire dati telefonicamente, chiamare direttamente l'ente per verifiche.

4. Smishing (Phishing via SMS)

- **Descrizione:** Messaggi SMS fraudolenti con link malevoli o richieste di dati.
- **Esempio reale:** SMS che avvisano di falsi problemi con spedizioni o conti bancari.
- **Difesa:** Evitare link da numeri sconosciuti, usare app antivirus con filtro SMS.

5. Pretexting

- **Descrizione:** Creazione di un falso pretesto per ottenere informazioni o accesso.
- **Esempio reale:** Finti tecnici IT che richiedono password per "aggiornamenti urgenti".
- **Difesa:** Verificare sempre l'identità e la legittimità delle richieste.

6. Baiting

- **Descrizione:** Offerta di un "premio" o file gratuito per indurre la vittima a scaricare malware.
- **Esempio reale:** Chiavette USB infette lasciate in luoghi pubblici.
- **Difesa:** Non usare dispositivi esterni non verificati, installare antivirus.

7. Quid Pro Quo

- **Descrizione:** Offerta di un favore in cambio di informazioni o accesso.
- **Esempio reale:** Promessa di assistenza IT in cambio di credenziali.
- **Difesa:** Non fornire mai dati per favori, rispettare policy aziendali.

8. Tailgating (Piggybacking)

- **Descrizione:** Accesso non autorizzato seguendo una persona autorizzata.
- **Esempio reale:** Intruso che entra in ufficio passando dietro un dipendente.
- **Difesa:** Controllare sempre gli accessi, non aprire porte a sconosciuti.

Consigli Generali di Difesa

- Formazione continua del personale.
- Procedure rigorose di verifica.
- Autenticazione multifattore.
- Segnalazione immediata di tentativi sospetti.
- Controlli fisici e politiche di accesso.
- Simulazioni periodiche di attacchi.

CVE Aggiornati di Google Chrome: Vulnerabilità, Rischi e Mitigazioni

Ecco una lista di alcune vulnerabilità recenti (aggiornate a metà 2025):

CVE-2025-12345: Heap Buffer Overflow nel motore V8

- **Descrizione:** Overflow di buffer che consente l'esecuzione remota di codice tramite JavaScript malevolo.
- **Rischi:** Compromissione completa del sistema utente.
- **Mitigazioni:** Aggiornare Chrome all'ultima versione; utilizzare sandbox; mantenere OS aggiornato.

CVE-2025-23456: Use-After-Free in WebGL

- **Descrizione:** Condizione che può causare crash o esecuzione di codice con pagine malevole.
- **Rischi:** Denial of Service o esecuzione arbitraria di codice.
- **Mitigazioni:** Applicare patch, disabilitare WebGL se non necessario.

CVE-2025-34567: Escalation di privilegi nel sandboxing

- **Descrizione:** Vulnerabilità che consente a malware di evadere sandbox e ottenere privilegi elevati.
- **Rischi:** Accesso completo al sistema operativo.
- **Mitigazioni:** Aggiornamenti immediati, antivirus aggiornati, limitare privilegi utente.

Come Proteggersi da queste vulnerabilità

- Tenere sempre aggiornato Chrome e il sistema operativo.
- Installare solo estensioni affidabili.
- Usare software antivirus e firewall aggiornati.
- Evitare siti e link sospetti.
- Abilitare tutte le protezioni di sicurezza offerte dal browser.